

Vendor Risk Decision Memo

PeopleFlow Inc. — HR Platform Vendor Onboarding for CloudScale Dynamics

UBI-2026-0039 · GRC Analyst Track · Advanced Stage, Project 2 · Evidence marker UBI-A6-A643A704516C
Prepared by: Rosemary Gift Nelson, GRC Analyst

1. Decision

Ruling: CONDITIONAL APPROVE

Every SIG claim except (partially) ENC-03 and LOC-02's non-conflicting edge has a verified technical or evidentiary problem, including an undisclosed-subprocessor finding that touches regulated PII outside the claimed region. Outright rejection is not required because every finding maps to a closeable, owned, fail-closed condition; but approval is conditional and processing must be suspended for any in-scope data class until Tier-0 conditions (COND-01, COND-02, COND-06, COND-07) close. This is not a prose-only conditional approval: every condition above has an executable monitor (see monitoring-plan.yaml) and a stated fail-closed action.

CEO approval required. Contract value USD 180,000 exceeds the USD 85,000 risk-acceptance threshold in the controlling assignment overlay; any residual-risk acceptance requires CEO sign-off.

This ruling means: PeopleFlow is not rejected outright, but no in-scope CloudScale data class may be processed (or must have processing suspended, if the 24 July 2026 planned launch already occurred) until the Tier-0 conditions in Section 4 close. Every condition carries an executable quarterly monitor (monitoring-plan.yaml) and a stated fail-closed action, per the hard acceptance gate that a conditional approval without executable fail-closed monitoring cannot pass.

2. Verification summary

Result	Count
Pass	9
Fail	11
Insufficient	3
Malformed	1
Total verdicts	24

Six SIG claims were tested (IAM-04, LOG-07, LOC-02, ENC-03, DEL-05, IR-08). Every one of them produced at least one fail or insufficient verdict against technical evidence, telemetry, or the vendor's own SOC 2 report — not against questionnaire text, which the hard acceptance gate forbids relying on.

3. Material findings (traceable to evidence-verdicts.json)

- AUDIT_EXCEPTION_CONTRADICTS_CLAIM** (LOG-07) — SOC 2 exception EX-CC7.2: alert-review evidence absent for 7 of 40 sampled days, contradicting the LOG-07 claim of daily review with retained evidence. `[input/assurance-and-contract.json :: $.assurance_report.exceptions[?(@.id=='EX-CC7.2')]]`

- **TLS_BELOW_MINIMUM** (ENC-03) — files.peopleflow.invalid observed at TLSv1.0; vendor-claimed minimum is TLSv1.2. *[input/vendor-telemetry.json :: \$.tls.observations[1] (endpoint=files.peopleflow.invalid)]*
- **SUCCESS_BEFORE_COMPLETION** (DEL-05) — DEL-710: status reported at 2026-06-20T12:00:00Z, completion event at 2026-06-20T12:14:00Z. *[input/vendor-telemetry.json :: \$.deletion_jobs[0] (job_id=DEL-710)]*
- **REGION_CLAIM_CONTRADICTED** (LOC-02) — AssistWorks (SP-02) processes ['support_case', 'employee_id'] in Philippines; LOC-02 claims data remains exclusively in us-east-1. *[input/vendor-telemetry.json :: \$.subprocessors[1] (id=SP-02, name=AssistWorks)]*
- **DUPLICATE_EVENT_ID** (general control) — event_id list has 4 entries and 3 distinct values. *[input/vendor-telemetry.json :: \$.privileged_access[*].event_id]*
- **PRIVILEGED_MFA_MISSING** (general control) — PA-002 (support-19, ap-southeast-1): mfa=False, approved_ticket=None. *[input/vendor-telemetry.json :: \$.privileged_access[event_id=PA-002].mfa]*
- **HASH_CHAIN_BROKEN** (general control) — PA-003.previous_hash=WRONG does not chain from PA-002.hash=98abc. *[input/vendor-telemetry.json :: \$.privileged_access[event_id=PA-003].previous_hash vs \$.privileged_access[event_id=PA-002].hash]*
- **CUSTOMER_CLOCK_DELAYED** (IR-08) — Notice clock basis is 'vendor_confirmation': the 72-hour window starts only when PeopleFlow itself confirms an incident, so the customer has no independent trigger. *[input/assurance-and-contract.json :: \$.contract.incident_notice.basis]*
- **UNDISCLOSED_SUBPROCESSOR** (LOC-02) — Telemetry shows subprocessor QueueNorth (SP-01) handling ['employee_id', 'email'] in us-east-1; this name/id does not appear in the DPA-disclosed subprocessor list (['AWS', 'HELP-SPHERE', 'MAIL-RELAY']). *[input/vendor-telemetry.json :: \$.subprocessors[0] (id=SP-01, name=QueueNorth)]*

Insufficient (missing/unverifiable, never promoted to pass):

- **EVIDENCE_NOT_SUPPLIED** (IAM-04) — IAM-04 evidence_supplied=false and no termination-event export exists in telemetry to test against.
- **BACKUP_PURGE_UNPROVEN** (DEL-05) — DEL-710: status=success, backup_purge_at=None.
- **ASSURANCE_MISSING** (general control) — HELP-SPHERE (tier_1_support, Philippines): assurance=self-assessment.

4. Conditions precedent (owner / deadline / evidence / fail-closed action)

ID	Description	Owner	Due	Fail-closed action
COND-01	PeopleFlow discloses QueueNorth, AssistWorks, ArchiveLane on the contractual subprocessor list (or ceases routing CloudScale Dynamics data through them) and confirms no other undisclosed subprocessors exist.	PeopleFlow Vendor Manager / CloudScale Chief People Officer	10d	Suspend data transmission to any subprocessor not on the disclosed list.
COND-02	PeopleFlow provides a corrected data-residency statement reflecting actual processing regions (Philippines, eu-west-1), or relocates processing to match the us-east-1-exclusive claim.	PeopleFlow Compliance Lead	15d	Treat LOC-02 as false for contractual purposes; apply cross-border transfer terms to all affected data classes until corrected.
COND-03	HelpSphere (tier-1 support, ticket/attachment access) provides an independent assurance report (SOC 2, ISO 27001, or equivalent) and enables session recording for privileged support access to attachments.	PeopleFlow Vendor Manager	30d	Restrict HelpSphere from attachment access until assurance is provided.
COND-04	PeopleFlow enforces MFA on all privileged support access; retroactively investigates the PA-002 non-MFA session(s) for unauthorized activity.	PeopleFlow Security Lead	7d	Suspend the affected actor's privileged access pending investigation.
COND-05	PeopleFlow explains and remediates the broken privileged-access hash chain (integrity of the audit log itself), and re-exports a verifiably unbroken log for the affected period.	PeopleFlow Security Lead	14d	Treat the access log as unverifiable for the affected period; do not rely on it for LOG-07 evidence until remediated.
COND-06	PeopleFlow corrects deletion-job status reporting to fire only after the completion event, and supplies backup-purge evidence (timestamp + verification) for every deletion job, including DEL-710.	PeopleFlow Data Protection Officer	30d	Treat DEL-05 as unproven; escalate to legal if termination deletion is contractually represented as complete before evidence exists.
COND-07	DPA is amended so the 72-hour notice clock starts at vendor discovery/should-have-discovered, not solely at vendor confirmation, and PeopleFlow commits to an interim notice within 24h of any suspected incident.	CloudScale Legal / PeopleFlow Legal	30d	Escalate any suspected incident internally at CloudScale on independent detection, without waiting on PeopleFlow confirmation.
COND-08	PeopleFlow remediates the EX-CC7.2 alert-review gap (7 of 40 days missing evidence) and demonstrates a full review cycle with retained evidence for one subsequent audit period.	PeopleFlow Security Lead	60d	Do not rely on LOG-07 as met until remediation evidence exists.
COND-09	PeopleFlow supplies a termination-access export (IAM-04) so the 24-hour de-provisioning claim can be tested against evidence rather than accepted on questionnaire text alone.	PeopleFlow Vendor Manager	15d	Treat IAM-04 as unverified; do not represent it as tested in any downstream audit.

5. Residual risk (remains even after all conditions close)

- Even after all conditions close, PeopleFlow remains a single vendor with access to regulated PII (bank details, tax IDs) and no customer-side ability to independently detect an incident before PeopleFlow chooses to confirm one.

- Historical processing that already occurred in undisclosed regions/subprocessors cannot be un-processed; conditions govern going-forward state only.
- SOC 2 Type II carve-out method means subservice organisations' controls are not directly tested by PeopleFlow's own auditor.

6. Alternatives considered

Reject outright: considered given that every SIG claim has a problem; not selected because every finding maps to a closeable, owned condition rather than an unfixable defect, and outright rejection would forfeit the leverage to force disclosure of the undisclosed subprocessors while the deal is still open. **Approve as-is:** rejected outright — the hard acceptance gate that trusting questionnaire text over failing technical evidence fails the decision applies directly; SIG claims cannot be accepted at face value here. **Defer:** considered, but with 24 conditions/verdicts already resolvable into concrete, owned actions, deferral would only delay accountability without changing the underlying facts.

7. Artifact-check log

Reserved for the mandatory replacement-export exercise: record here which export staff swapped, the resulting delta in evidence-verdicts.json, and whether it changed the ruling, a condition, or neither. See tests/test_replacement_export_rehearsal.py for the rehearsed version run before submission.

Source hashes (frozen at generation time)

input/vendor-claims.json :: 21feb862f2fd831d893144386cb6ad12fe7ca9c63832cf4707461b8eadf0d670

input/vendor-telemetry.json :: 6d744d4d5a2e3b4e2385176c6d105c8593dbbf8f2451601f86d2a54e79c947d6

input/assurance-and-contract.json :: 3407ed2a89bbc18e3671f4c53950befd8db913c9ba02ab2ddcc244da0155474a